

Defence to DDoS Attacks

Module 47

Duration: 24:56

Video: https://www.youtube.com/watch?v=w_XZu6Rc0jM

Course Coordinator - Dr Maninder Singh, Professor and Dean, Academic Affairs, Thapar University, Patiala

Subject Expert - Dr Abhinav Bhandari, Department of Computer Engineering, Punjabi University, Patiala

Auto-generated YouTube transcript for personal study. Spoken wording belongs to the original lecture. Follow the video link above; this file is not an official CEC/SWAYAM publication.

dear viewers in the previous lecture we have gone through the basics of Doos attacks motivation behind these attacks and classification of Dos attacks in today's lecture we will be discussing few aspects of DS attacks that that make defending against them difficult after that we will focus on challenges and goals for designing an ideal defense solution in the last part of the lecture we will learn some of the tips that can be helpful for preventing the system from being attacked by the DS attackers let's begin by learning why dos problem is hard to solve dos defense is a challenging issue among the cyber security Community the following characteristics of Dos flooding attacks make these attacks very effective for the attacker's purpose and extremely challenging for the defense

simplified procedures of launching these attacks there are many Doos tools that can be easily downloaded or otherwise obtained and set into action they make agent Recruitment and activation automatic and can be used by inexperienced users these tools are exceedingly simple and some of them have been around for years still they generate effective attacks with little or no tweaking next is traffic variation the similarity of attack traffic to legitimate traffics makes separation and filtering extremely hard unlike other security threats that need specially crafted packets example intrusions WMS virus flooding attacks need only high traffic volume and can vary packet contents and headers value at its will next comes the IP spoofing IP spoofing makes the attack traffic appear as if it

2 minutes, 1 second comes from numerous legitimate clients this defeats many resource sharing approaches that identify a client by his IP address if IP address were eliminated agents could potentially be distinguished from legitimate clients by their aggressive sending patterns and their traffic could be filtered in the presence of Ip spoofing the victim sees a lot of service initiation request from numerous seemingly legitimate users while the victim could easily tell those packets apart from ongoing Communications with the legitimate users it cannot distinguish new legitimate requests for service from the attack ones thus the victim cannot serve any new users during the attack if the attack is long the damage

to the victim's business is obvious another issue is huge volume of traffic the high volume of attack traffic at the victim not only overwhelms the targeted resource but makes traffic profiling hard at such high packet rates the defense mechanism can do only simple per packet processing the main challenge of Dos defense is to discern the legitimate from the attack traffic at higher packet speeds next is several zombies machine can be another Factor the strength of adidos attacks lies in numerous agent machines distributed all over the internet with so many agents the attacker can take and even the largest networks and he or she can vary his or her attack by deploying subsets of agents at time or sending few packets from each agent machine wearing attack strategies defeat many defense

mechanism that attempt to trace back the attack to its source even the cases when the attacker does not vary the attacking machines the mere number of Agents involved makes Trace back and un attractive solution what if we knew the identities of 10,000 machines that are attacking our Network this would hardly get any closer to stopping the attack the situation would clearly be simplified if the attacker were not able to recruit so many agents as discussed the general increase of internet host and more recently the higher percentage of novice internet users suggest that pool of potential agents will only increase in future furthermore the the distributed internet management model makes it unlikely that any security mechanism will be widely

deployed thus even if we found ways to secure machines permanently and make them in previous to the attacker intrusion attempts it would take many years until these machines would sufficiently deploy to impact the Dos threat feak spots in the internet topology the current Internet Hub and spoke topology has a handful of Highly connected and very well provisioned spots that relay traffic for rest of the internet these hubs are highly Provisions to handle heavy traffic in the first place but if these few spots were taken down by the attacker or heavily congested the internet would grind to a halt amassing a large number of agent machines and generating heavy traffic passing through those hotspots

would have devastating effect on global community so in n sh let's face it a flooding based Doos attack seems like a perfect crime in the internet attack tools and agent machines are abundant and easily obtainable a sufficient attack volume is likely to bring the strongest victim to its knees and the right mixture of attack traffic along with the IP spoofing will defeat attack filtering attempts since numerous business rely heavily on the online assess taking that way is show sure to inflict considerable damage to the victim and finally IP spoofing numerous agent machines and lack of automated tracing mechanism across the network gruny little to no risk to protect of being caught next we will discuss about the challenges of DS

defense the challenges in designing DS defense system fall roughly into two categories technical challenges and the social challenge technical challenges incompasses problems associated with the current Internet Protocol and characteristics of Dos threat Social Challenges on the other hand largely pertain to the manner in which a successful technical

solution will be introduced to the internet users and accepted and widely deployed by these users the main problem that prevails in both Technical and social issues is the problem of large scale dos is is a distributed threat that requires a merit of overlapping solutions to various aspects of Dos problem which must be spread across the internet because

attacking machines may be spread all over the Internet clearly attack streams can only be controlled if there is a point of Defense between the agents and the victims one approach is to place one defense system close to the victim so that it monitors and controls all the incoming TR traffic this approach has many deficiencies the main one being that system must be able to efficiently handle and process huge traffic volume the other approach is to divide this workload by deploying distributed defense defense system must be then deployed in a widespread manner to ensure effective action for any combination of agent and victim machines as WID spread deployment cannot be granted the technical challenge lines in designing effective defenses that can provide reasonable performance even if

they are sparsely deployed the social challenge lies in designing an economic model of a defense system in a manner that motivates large scale deployment in the internet we will discuss first about the technical challenges the distributed nature of DS attacks similarity of the attack packets to the legitimate ones and the use of Ip spoofing represents the main technical challenge to the designing effective Doos defense system as discussed in the previous section in addition to that advance of Dos defense research has historically been hindered by the lack of attack information and absence of standardized evaluation and testing approaches the following list summarizes and discusses technical challenges for DS defense

need for distributed response at many points in the internet there are many possible dos attacks very few of which can be handled only by the victim thus it is necessary to have distributed possibly coordinated response system it is also crucial that response be deployed at many points in the internet to cover diverse choices of agents and victim since the internet is administrated in a distributed manner wide deployment of any defense system or even various system that could cooperate cannot be enforced or granted this discourages many researchers from even considering distributed Solutions next comes the lack of detailed attack information it is widely believed that reporting occurrences of attack damages the business reputation of victim

Network therefore very limited information exist about various attacks and incidents are reported only to government organizations under obligation to keep them secret it is difficult to design a imaginative solution to the problem if one cannot become familiar with it note that the attack information should not be confused with the attack tool information which is publicly available at many internet sites attack information would include the attack type time and duration of attack number of Agents involved if this information is known attempted response and its Effectiveness and damage is suffered lack of defense system benchmarks many vendors make bold claims that their solution completely handles

the deos problem there is currently no standardized approach for testing dos defense system that would enable their comparison and characterization this has two detal influences on dos research since there is no attack Benchmark defense designers are allowed to present those tests that are most advantageous to their system and researchers cannot compare actual performance of their solution to the existing defenses instead they can only comment on design issues next comes the difficulty of large scale testing Doos defense need to be tested in a realistic enir environment this is currently impossible due to the lack of large scale test beds safe ways to perform live distributed experiments across the internet or detailed and

realistic simulation tools that can support several thousands of nodes Claim about defense system performance are thus made based on small scale experiments or simulations are not credible some test bits are in use right now by DS resers example Planet lab and IMU lab now we will discuss about the Social Challenges many dos defense systems require certain deployment patterns to be effective those patterns fall into several category complete deployment a given system is deployed at each host router or network in the internet next is continuous deployment a given system is deployed at host or routers that are directly connected next is large scale widespread deployment the majority of hosts in the internet deploy a given System complete deployment at specified points in the

internet there is a set of carefully selected deployment points All Points must deploy the proposed defense to achieve the desired security modification of widely deployed internet protocols such as tcpip or HTTP next we will discuss that what are the goals necessary to have a strong and effective defense system following are some of Doos defense goals which Doos defense strategies strive to achieve first is Effectiveness a good Dos defense should actually defend it should provide either effective prent prevention that really makes attacks impossible or effective reaction ensuring that dos effect goes away in the case of reactive mechanism the response should be sufficiently quick and automated to ensure that the

target does not suffer seriously from the attack next goal should be completeness a good Dos defense should handle all possible attacks if that degree of perfection is impossible it should at least handle a large number of them a mechanism that is capable of handling an attack based on TCP sin flooding but cannot offer any assistance if a ping flood arrives is clearly less valuable than a defense that can handle both styles of attack thus a preventive measures like TCP sin cookies helps but is not sufficient unless coupled with other defense mechanisms completeness is also required in detection and reaction if our detection mechanism does not recognize a particular pattern of incoming packet as an attack pre assumably it will not work

invoke any response and attack will succeed while completeness is an obvious goal it is extremely hard to achieve since attackers are likely to develop new types of attacks specially designed to bypass existing defense moreover flash events discussed need clear-cut distinctions from dos attacks next is minimum collateral damage as discussed above the core goal of Doos defense is not to stop dos attack packets but to ensure that legitimate users can

continue to perform their normal activities despite the presence of Dos attack clearly a good defense mechanism must achieve it some legitimate traffic may be flowing from sides that are also sending attack traffic other legitimate traffic is destined for nodes on same network as the target node there may be a

legitimate traffic that is neither coming from an attack machine nor being delivered to the targets network but perhaps shares some portion of its path through the internet with some of the attack traffic and some of the legitimate traffic meares other characteristics with the track traffic such as application protocol or destination Port potentially making it difficult to distinguish between them none of these legitimate traffic categories should be distributed by the Dos defense mechanism however dos defense mechanisms are not able to characterize dos traffic accurately and drop a part of legitimate traffic also this dropping of legitimate traffic is called coal literal damage since dos attackers often strive to conceal their tra traffic in the legitimate traffic stream it is common

for legitimate traffic to closely resemble the attack packets so the problem of collateral damond is real and serious especially in case of flash events protecting legitimate traffic that is minimizing collateral damage is very important next comes the low Falls positive rates defense mechanism should Target only true dos attacks preventive mechanism should not have the effect of hurting other forms of net traffic reactive mechanism should be activated only when a Doos attack is actually underway a detection scheme can falsely detect an attack in a situation when no attack was actually happening this is called false positive these false positive CA collateral damage as they trigger the filtering mechanism when there is actually no attack moreover reactive mechanisms are likely to incure some

cost the cost is in terms of extra CPU Cycles memory and delay caused on processing of all packets low deployment and operational cost dos defense are meant to allow systems to continue operations during DS attacks the cost associated with the defense system must be common straight with Benefits provided by it for commercial Solutions there is an obvious economic cost of buying the hardware and software required to run it usually there are also significant system administration cost with setting up new security equipment or software depending upon the character of dedos defense mechanism it may require frequent ongoing Administration for example example a mechanism based on detecting signatures of particular attacks will need to

receive update as new attacks are characterized requiring either manual or automated actions other operational cost relate to overheads imposed by the defense system A system that performs stateful inspection of all incoming packets May delay each packet for example or a system that throttles data streams from suspicious sources may slow down any legitimate interactions with those sources unless such cost are extremely low or extremely rare paid they must be balanced against benefits of achieving some degrees of protection against dos attacks how we can defend against these attacks our next part of discussion will focus on the defense

Doos defense modules are shown in the Fig figure generally there are four broad

categories of defense against dos attacks first is attack prevention second is attack detection third is attack Source identification and fourth is attack reaction attack preventions aims to stop attacks before they can reach their target it refers to the filtering spoof packets close to or at the attack sources which is one of the most effective defense approaches for dos attacks that use poofed traffic attack detection aims to detect dos attacks when they occur attack detection is an important procedures to direct any further action it is the process of detecting the attack based on the traffic feature distribution signature based detection techniques are not applied for dos defense due to everchanging nature of signature of

attacks anomaly based detection techniques are suitable for for this purpose next is attack Source identification which aims to locate the attack sources regardless of whether the source address field in which packet contains enormous information it is a crucial steps to minimize the attack damage and provide prevention to the potential attackers next comes the attack reactions with which aims to eliminate or curtail the effects of an attack it is the final step in defending against dos attacks and therefore determines the overall performance of the defense mechanism the challenge of the attack reaction is however to filter and attack traffic without disturbing the legitimate traffic in the last part of the discussion we will learn some of the important tips which helps us to protect

our system from being attacked by dos first is Implement router filters this will lessen your exposures to certain denial of service attacks additionally it will Aid in preventing users on your network from effectively launching certain denial of service attacks second if they are available for your system install patches to guard against TCP sin flooding this will substantially reduce your exposure to those attacks but may not eliminate the risk entirely third is disable any unused or unneeded Network Services this can limit the ability of an intruder to take advantage of those services to execute a denial of service attack next is enable quota systems on your operating system if they are available for example if your operating system supports dis quotas enable them

for all accounts especially accounts that operate Network Services in addition if your operating system support partitions or volume consider partitioning your file system so as to separate critical functions from other activities next is observe your system performance and establish baselines for ordinary activity next use the baselines to cause unusual levels of disk activity CPU uses or network traffic next routinely examine your physical security with respect to your current needs consider servers routers un attending terminals network access points wiring closets environmental systems such as air and power and other components of your system next use trip wire or similar tool to detect changes in the configuration information or other files next invest in redundant and fall

TN Network configurations establish and maintain regular backup schedules and policies particularly for important configuration information next establish and maintain appropriate password policies especially assessed to highly privileged account such as Unix root or Microsoft Windows administration at last I would like to conclude that DDoS attacks is a devastating attack among the cyber community and the defense to this attack 24 minutes, 1 second is eluded so far though there are many academic and Commercial Solutions present in the market in this lecture we have discussed some of the factors that made DDoS attack problem harder to solve we have also learned some of the key challenges and goals for designing an ideal defense solution some tips to manage your system against these attacks are also

highlighted thank you all